

Integrator Concentration: Supply-Chain Attack Surfaces in Cloud-Bridged Building Automation Networks

Cameron Warren
cwarre33@uncc.edu

Department of Computer Science
University of North Carolina at Charlotte

May 1, 2026

Abstract

We discover a previously uncharacterized pattern in building automation infrastructure security: **integrator concentration**, where a single third-party endpoint maintains simultaneous Foreign Device registrations with multiple geographically separated building control networks. This concentration creates a supply-chain attack surface—compromise of one monitoring station yields access to multiple critical facilities. Through passive analysis of internet-exposed BACnet Broadcast Management Devices, we identify and characterize one such concentrator bridging at least two distinct building networks over a 47-day observation window. We discuss responsible disclosure implications and propose detection methodologies for identifying concentrator infrastructure at scale.

1 Introduction

Supply-chain attacks have emerged as a dominant pattern in cyber-physical system compromises: rather than targeting hardened endpoints directly, adversaries compromise shared infrastructure (software updates, managed services, third-party integrations) to gain access to multiple downstream targets.

Building automation systems have been considered relatively isolated from threat vectors that plague networked industrial control systems. We discover this isolation assumption may be incorrect.

1.1 The Concentration Phenomenon

Through analysis of internet-exposed BACnet BBMDs (Building Broadcast Management Devices), we identify a pattern where multiple building networks maintain independent tunnels to a shared external endpoint—suggesting third-party integrator management infrastructure bridging client facilities.

This pattern enables:

- Horizontal movement between facility networks via integrator infrastructure
- Scale advantages for adversaries (one compromise, multiple targets)
- Attribution challenges (attack appears to originate from trusted third-party)

1.2 Key Finding

Two distinct BBMDs, separated by approximately 4,000 km in different municipalities, maintain coordinated Foreign Device registrations with the same public IP address (216.67.73.166) over a 47-day observation window.

1.2.1 Contributions

1. **Formalization of Integrator Concentration:** We define and characterize a novel supply-chain attack surface in building automation.
2. **Empirical Discovery:** We identify and document a real concentrator endpoint serving at least two distinct building networks over an extended period.
3. **Detection Framework:** We propose passive OSINT methods for identifying concentrator infrastructure at scale.
4. **Disclosure Study:** We discuss responsible disclosure challenges when both integrator and building operator are affected parties.

2 Background

2.1 BACnet Foreign Device Registration

BACnet supports cross-subnet communication through Foreign Device registration: a device on one subnet registers with a BBMD on another, creating a tunnel for forwarded broadcasts. Architecturally, this enables:

- Multi-building campus networks (intended use)
- Remote monitoring by third-party integrators (accepted use)
- Cloud-managed building automation (emerging pattern)

Standard security assumptions: Foreign Devices are within the same organization’s control.

2.2 Supply-Chain Attacks in Industrial Control

Prior research documents:

- Software supply chains (compromised updates affecting multiple facilities)
- MSP (Managed Service Provider) compromises cascading to clients
- Vendor credential breaches exposing customer networks

Gap: No prior work has characterized third-party infrastructure concentration in building automation specifically.

3 Discovery and Methodology

3.1 Data Source

Longitudinal Shodan dataset: BBMDs with BACnet/WP fingerprints sampled 2026-03-04 to 2026-04-20, with extracted Foreign Device Tables.

3.2 Concentration Detection

We define concentrator indicators:

1. **Multi-host FD registration:** Same FD IP across multiple BBMDs
2. **Temporal overlap:** Simultaneous or overlapping registrations
3. **Geographic separation:** BBMDs in distinct locations
4. **Behavioral similarity:** Similar port/TTL patterns

3.3 Confirmed Concentrator: 216.67.73.166

Attribute	Observation
Connected BBMDs	Minimum 2 confirmed
BBMD 1	66.58.248.125 (United States)
BBMD 2	24.237.132.230 (United States, different region)
Registration duration	47 days continuous
Port behavior	13 rotating source ports each
Last seen	2026-04-20 (both BBMDs)

Table 1: Confirmed Concentrator Characteristics

3.4 Passive Attribution

Without active connection to the concentrator endpoint, we infer likely integrator nature from:

- Rotating-port behavior (suggesting NAT traversal, common in consumer-grade integrator setups)
- Persistence over 47 days (not transient, intentional service)
- Geographic distribution (not colocated, infrastructure service)

4 Attack Surface Analysis

4.1 Threat Model

Adversary capability: Compromise of integrator monitoring station.

Attack path:

1. Gain access to integrator endpoint through phishing, credential theft, or infrastructure vulnerability
2. Leverage existing Foreign Device registrations as persistent tunnels into client building networks
3. Issue BACnet commands from trusted FD position

Advantages over direct facility targeting:

- Single compromise, multiple facilities
- Appears as legitimate integrator traffic
- Bypasses facility-level perimeter defenses

4.2 Impact Scenarios

Building automation systems control:

- HVAC (climate, air handling, temperature)
- Access control (doors, elevators)
- Fire safety systems

- Critical infrastructure cooling

Compromise enables:

- Climate manipulation affecting equipment/occupants
- Access bypass at critical facilities
- Ransomware pivot to IT networks via HVAC bridge

5 Detection at Scale

5.1 Large-Scale Concentrator Discovery

Proposed methodology for passive detection:

1. Harvest full Shodan BACnet dataset ($\sim 40,000$ BBMDs indexed)
2. Extract all Foreign Device Table entries
3. Group by FD IP, counting distinct BBMD registrations
4. Filter for multiple BBMDs per FD with geographic separation
5. Validate persistence over time window

Expected yield: Based on our 17-BBMD sample showing 1 concentrator, full dataset may reveal 50–100 additional concentrator endpoints.

5.2 False Positive Mitigation

- **Exclude colocated BBMDs:** Same datacenter = different threat model
- **Require temporal overlap:** Not sequential use
- **Behavioral similarity:** Consistent port/TTL patterns

6 Responsible Disclosure Challenges

6.1 Multi-Party Affected

Concentrator findings implicate multiple parties:

- Building operators (facilities with exposed BBMDs)
- Integrator (owner of concentrator endpoint)
- Potentially building occupants/residents

Standard disclosure assumes single responsible party.

6.2 Attribution Barriers

Identifying integrators from passive data requires:

- IP-to-ASN mapping
- WHOIS lookup (often privacy-protected)
- Business registration search

Failure modes: privacy-protected WHOIS, offshore registration, home-office integrators.

6.3 Proposed Approach

1. Attempt integrator attribution first
2. If successful: disclose to integrator as primary responsible party
3. Notify building operators with guidance on FD registration audit
4. Coordinate remediation timing

7 Conclusion

Integrator Concentration represents a novel supply-chain attack surface in building automation infrastructure. Our empirical discovery of a confirmed concentrator bridging multiple facilities demonstrates the pattern is not theoretical—it is actively deployed and discoverable through passive OSINT methods.

The concentration phenomenon suggests building automation security assessments must extend beyond facility boundaries to include third-party management infrastructure that provides bridged access.

Acknowledgments

This research was conducted using only publicly indexed Shodan data. All findings have been reported to US-CERT for coordination with affected parties.